

Audit-Tail Final Report

Project: `vulnerable-invoice-service` · Stage 5 (aggregate) · Generated 2026-07-03 · Health Score: **60 / 100** Grade C — needs attention

Executive summary

- **23** dependencies scanned on `main` (`61ed8c3`) · **82** CVE findings across **8** vulnerable/flagged coordinates.
- **Supply-chain:** `BLOCK` on PR #59 — 1 license violation + 1 untrusted HTTP repository (typosquat resolved).
- **Licenses:** 1 violation persists (GPL-2.0-with-FOSS-Exception on `mysql-connector-java`) — not clearable by a version bump, tracked in issue #58.
- **Remediation:** consolidated fix PR #59 open — typosquat removed, `log4j-core/api` → 2.25.4, `jackson-databind` → 2.22.0, `protobuf-java` pinned → 3.25.5, `guava` → 32.0.1-jre, `commons-lang3` → 3.18.0, `commons-io` → 2.14.0.
- **Latest gate outcome:** `BLOCK` — 1 unresolved HIGH CVE (`mysql-connector-java`, not touched by this PR), the license violation, and the pre-existing untrusted mirror.

Health score breakdown

Factor	Deduction
Unresolved HIGH-band dependency (<code>mysql-connector-java</code> , CVE-2023-22102)	-8
Unresolved MEDIUM-band dependencies	-0
Supply-chain <code>BLOCK</code> findings (license violation + untrusted repo, 2 × -10)	-20
Outdated major-version direct dependencies (<code>log4j-core</code> , <code>log4j-api</code> , <code>guava</code> , <code>junit-jupiter</code> , 4 × -3)	-12
Score	60 / 100

Baseline on `main` before this run's remediation: **27 / 100 (Grade D)** — 4 HIGH-band + 3 MEDIUM-band dependencies, 2 supply-chain blocks (typosquat + untrusted repo), 5 major-outdated direct dependencies. This run's PR #59 lifts the score to **60 / 100 (Grade C)**, a **+33** improvement, once merged. Full remediation still requires: (1) replacing `mysql-connector-java` to clear both its HIGH CVE and its license violation, and (2) removing the untrusted HTTP mirror from `pom.xml`.

Top risks (ranked, post-remediation state on PR #59)

Coordinate	Risk	Band	Top CVE / issue	Status
<code>mysql:mysql-connector-java:8.0.30</code>	—	<code>HIGH</code>	CVE-2023-22102 (8.3) + GPL-2.0 license violation	Not fixed — issue #58
<code>pom.xml</code> <code>internal-untrusted-mirror</code>	—	<code>HIGH</code>	Untrusted HTTP repository (MITM risk)	Not fixed — pre-existing
<code>com.google.guava:guava:32.0.1-jre</code>	5.5 (resolved)	<code>OK</code>	CVE-2023-2976 — cleared	Fixed in PR #59
<code>org.apache.logging.log4j:log4j-core / log4j-api</code>	7.8 (resolved)	<code>OK</code>	CVE-2021-44228 (Log4Shell) — cleared	Fixed in PR #59
<code>com.fasterxml.jackson.core:jackson-databind</code>	7.8 (resolved)	<code>OK</code>	CVE-2020-9548 + 55 more — cleared	Fixed in PR #59

Remediation activity

Dependency	Change	CVEs cleared	Status
com.fastxml.jackson.core:jackson-databind	removed (typosquat)	n/a — supply-chain	in PR #59
log4j-core / log4j-api	2.14.1 → 2.25.4	CVE-2021-44228, -45046, -45105, -44832 + 5 more	in PR #59
jackson-databind (real)	2.9.8 → 2.22.0	CVE-2020-9548 + 55 more	in PR #59
protobuf-java (transitive)	3.19.4 → 3.25.5 via dependencyManagement	CVE-2022-3171, -3509, -3510, CVE-2024-7254	in PR #59
guava	24.1.1-jre → 32.0.1-jre	CVE-2023-2976, CVE-2020-8908	in PR #59
commons-lang3	3.4 → 3.18.0	CVE-2025-48924	in PR #59
commons-io	2.4 → 2.14.0	CVE-2024-47554	in PR #59
mysql-connector-java	not bumped — version bump doesn't clear GPL-2.0 flag	CVE-2023-22102 unresolved	issue #58 (human follow-up)

Gate (Stage 4) — current verdict: BLOCK

Check	Result
Unit tests (mvn clean test)	PASS — 2/2 passed
OWASP Dependency-Check CVE gate	FAIL — 1 unresolved HIGH (mysql-connector-java, CVE-2023-22102)
Supply-chain audit (Syft + Gype)	FAIL (BLOCK) — license violation + untrusted repo

Note: `mvn clean verify` also fails on the pre-existing JaCoCo 80% line-coverage gate (Issue #6), seeded intentionally in this demo repo. That failure is unrelated to dependency/supply-chain changes and was not used to derive the gate verdict above.

Required actions before PR #59 can pass the gate

1. Replace or upgrade `mysql:mysql-connector-java` past 8.1.0 (or migrate to `com.mysql:mysql-connector-j`) to clear CVE-2023-22102 — see issue #58.
2. Resolve the GPL-2.0 license violation on the MySQL driver (swap to MariaDB Connector/J or an approved internal driver, or obtain an explicit license exception) — issue #58.
3. Remove the `internal-untrusted-mirror` HTTP repository entry from `pom.xml`, or replace it with an HTTPS, allowlisted source.

Demo script — vulnerable → detected → scored → fixed → gated

1. **Show a vulnerable project** — `pom.xml` on `main` declares `log4j-core:2.14.1` (Log4Shell) and a typosquatted `com.fastxml.jackson.core:jackson-databind`.
2. **Detect** — Stage 1 scan (`risk_scoring_agent`) finds 82 CVE findings across 8 vulnerable/flagged coordinates, writes `depscan-report.json`.
3. **Score** — Stage 2 ranks them; `jackson-databind / log4j-core / log4j-api` float to the top of `depscan-risk-report.json` at risk score 7.8 (HIGH band).
4. **Fix** — Stage 3 (`depscan-auto-remediation`) batches 7 safe fixes onto `fix/depscan-20260703-060919` and opens consolidated PR #59, with a changelog and CVE table.
5. **Gate** — Stage 4 (`pr_validation_agent`) runs the build + three checks on PR #59; verdict is **BLOCK** (mysql-connector-java CVE + license + untrusted repo remain), posted as a PR review.

6. **Prove** — once the required actions above are merged, re-run this report; expect health score to move from 60 → ~90+ (Grade A) as the last BLOCK findings clear.

Pre-flight checklist: Java 17+, Maven on PATH, Syft/Grype installed, `GITHUB_TOKEN` /GitHub MCP authenticated for the target repo, demo repo checked out at a known commit (`61ed8c3` for this run).

Rollback note: this run only ever pushes a new `fix/depSCAN-*` branch and opens PR #59 / issue #58 — `main` is untouched, so the demo resets by simply deleting the branch/closing the PR if a clean re-run is needed.

Aggregated from `depSCAN-report.json`, `depSCAN-risk-report.json`, and `depSCAN-supplychain-audit.json`. Generated by the Dependency & Supply-Chain Plugin — Stage 5.